

SecureOrg Inc.

PCI DSS Compliance Framework

Configuration Management Policy

Document Reference:	CMP-005
Version:	1.3
Effective Date:	April 14, 2026
Document Owner:	Chief Technology Officer
Classification:	CONFIDENTIAL
Review Cycle:	Annual
Framework:	PCI DSS v4.0

This document contains confidential and proprietary information. Unauthorized disclosure is prohibited.

1. Purpose and Scope

1.1 Purpose

This Configuration Management Policy defines the requirements for establishing, maintaining, and verifying secure configurations for all system components within SecureOrg Inc., with priority on the cardholder data environment. The Policy ensures compliance with PCI DSS v4.0 Requirements 2 (Apply Secure Configurations) and 12.3 (Manage Configuration Standards), reducing the attack surface by eliminating insecure default settings and unauthorized components.

1.2 Scope

This Policy applies to all hardware and software components including servers, workstations, network devices, databases, operating systems, applications, cloud instances, containers, and virtual machines — particularly those within or connected to the CDE.

2. Configuration Baselines

2.1 Baseline Development

Secure configuration baselines (hardening standards) shall be developed and maintained for all system types deployed in the CDE. Baselines shall be derived from and consistent with:

- Center for Internet Security (CIS) Benchmarks at Level 1 or 2 as appropriate
- Vendor security guides and hardening documentation
- NIST Special Publication 800-70 (National Checklist Program)
- PCI SSC information supplements on hardening
- Industry-specific security standards and regulatory requirements

Configuration baselines shall be developed for at minimum: Windows Server, Linux distributions in use, network devices (firewalls, routers, switches), database platforms (Oracle, SQL Server, PostgreSQL), web servers (Apache, Nginx, IIS), hypervisors and container platforms, and cloud service configurations.

2.2 Baseline Content Requirements

Each configuration baseline shall address at minimum:

- Removal or disabling of all default and unnecessary accounts
- Changing of all default passwords and credentials
- Removal or disabling of all unnecessary services, protocols, and ports
- Enabling required security services (logging, antivirus, file integrity monitoring)
- Network interface and firewall configurations
- Logging and auditing configuration requirements
- OS and application hardening settings (registry, kernel parameters, etc.)
- Encryption and cryptographic protocol configurations

3. Configuration Implementation

3.1 New System Deployment

All new systems deployed to the CDE or connected environments must:

- Be built from approved, hardened base images maintained by the Infrastructure team

- Have the applicable configuration baseline applied before connecting to the production network
- Pass automated compliance scanning with a score of 95% or higher before go-live
- Receive documentation of installed components, configurations, and rationale for any exceptions
- Be registered in the Configuration Management Database (CMDB)

3.2 Infrastructure as Code

Where infrastructure as code (IaC) is used for system provisioning:

- IaC templates must encode approved security baselines
- IaC code must be stored in version-controlled repositories with access controls
- IaC changes are subject to the Change Control Policy (CCP-004)
- IaC templates must be scanned with approved security tools before deployment

3.3 Configuration Documentation

For each system type, the following documentation shall be maintained:

- Approved baseline configuration document (versioned)
- List of services, daemons, protocols, and ports enabled with business justification for each
- List of users and groups configured
- Evidence of compliance scan results
- Exceptions from the baseline with risk acceptance documentation

4. Configuration Monitoring and Compliance

4.1 Automated Compliance Scanning

Automated configuration compliance scanning shall be conducted:

- Upon initial system deployment (before production release)
- Following all changes to CDE systems
- Weekly for all CDE systems as a continuous compliance check
- Monthly for all other systems

Compliance scan results shall be reviewed within 48 hours. Deviations from the approved baseline shall be treated as change control violations and investigated accordingly.

4.2 File Integrity Monitoring

File Integrity Monitoring (FIM) shall be deployed on all CDE systems to detect unauthorized changes to:

- Critical operating system files and directories
- Application binaries and configuration files
- Security software and tools
- Log files and audit trails

FIM alerts must be reviewed within 24 hours. FIM solutions must be configured to alert in real-time for changes to security-critical files.

4.3 Configuration Drift Management

Configuration drift — deviations from the approved baseline that occur over time — must be actively managed:

- Automated configuration management tools (Ansible, Chef, Puppet, or equivalent) shall be used to enforce baselines where feasible
- Configuration drift reports shall be generated weekly and reviewed by system owners
- Significant drift shall be remediated within 48 hours for CDE systems
- Persistent drift shall be escalated to the CISO and treated as a potential security incident

5. Network Configuration

5.1 Network Device Hardening

All network devices in the CDE shall be configured to:

- Disable Telnet; use SSH version 2 exclusively for management
- Implement SNMP v3 with strong authentication; disable SNMP v1 and v2c
- Disable unnecessary network services including web management interfaces where not required
- Implement access control lists (ACLs) restricting management access to authorised IP addresses

- Enable centralized logging to the SIEM
- Implement network time protocol (NTP) synchronization to approved time sources

5.2 Firewall Configuration Standards

Firewall configurations shall be reviewed at least every 6 months and shall include:

- A deny-all default rule with explicit allow rules for required traffic only
- Network segmentation rules isolating the CDE from non-CDE environments
- Anti-spoofing rules blocking traffic with illegitimate source addresses
- Stateful inspection enabled
- Logging of all rule matches for denied traffic
- Documented justification for each allow rule

6. Cloud Configuration Management

6.1 Cloud Security Posture Management

For cloud environments within the CDE scope:

- Cloud Security Posture Management (CSPM) tools shall be deployed to continuously monitor cloud configurations
- Cloud configurations shall align with the CIS Benchmarks for the relevant cloud provider
- Public access to storage accounts and databases shall be disabled by default
- Encryption must be enabled for all cloud storage and databases containing CHD
- Cloud IAM configurations shall enforce least privilege and MFA
- Cloud configuration changes are subject to the Change Control Policy

6.2 Container and Kubernetes Security

Container environments in the CDE shall be configured to:

- Use minimal base images from approved registries
- Run containers as non-root users
- Implement pod security policies or admission controllers
- Scan container images for vulnerabilities before deployment
- Implement network policies restricting inter-container communication

7. Exception Management

7.1 Baseline Exceptions

Deviations from configuration baselines require formal exception management:

- Document the specific deviation and business justification
- Conduct a security risk assessment of the deviation
- Implement compensating controls where possible
- Obtain CISO approval
- Record in the exception register with an assigned expiry date (maximum 90 days)
- Review at expiry: remediate, extend with renewed approval, or formally accept residual risk

8. Revision History

1.0	Jan 15, 2024	Initial release	CTO Office
1.1	May 20, 2024	Added cloud and container sections	Security Team
1.3	Apr 14, 2026	Annual review; IaC section; drift management updates	CTO/CISO